

Non Sequitur Publishing · White Paper

Tool Orchestration as a Confused-Deputy and Privilege-Compounding Surface

Justin H. Kuiper, CISSP

Written: 2026-05-13 · v0.1-seed

Abstract

Each tool invocation in an agentic chain is an **independent trust decision**. Chained tool calls compose as a privilege-aggregation surface where individually-safe capabilities become collectively unsafe. The classical **confused deputy** problem re-emerges in agentic operation at compositional scale: an agent with legitimate access to tools A, B, and C may be induced — through prompt injection, context manipulation, or state-state substitution — to compose $A \rightarrow B \rightarrow C$ in a sequence that achieves an outcome no individual operator authorized. The composition is the attack.

This paper argues that agentic tool orchestration requires a ***compositional threat model*** and a corresponding defensive doctrine: ***per-call authorization gates*** (not session-level trust) and ***operator-defined composition policy*** that constrains which tool sequences are authorized for which purposes. The thesis extends the classical principle of least authority with a new principle — **trust composition** — that addresses the structural gap where privilege-aggregation emerges from authorized-individual-actions.

Section 2 develops the parent HGC³AE² framing and surfaces the gap in current authorization frameworks. Section 3 formalizes trust composition as the operational problem: privilege compounding, confused-deputy at compositional scale, and the security composition requirement. Section 4 specifies per-call authorization gates and the composition-policy surface, with explicit reference to the object-capability model as a constructive alternative to ACL-based session-level trust. Section 5 places the discipline within MITRE ATT&CK; and OWASP LLM Top 10. Section 6 closes with limitations.

How to cite

Justin H. Kuiper, CISSP (2026). *Tool Orchestration as a Confused-Deputy and Privilege-Compounding Surface* (v0.1-seed). Non Sequitur Publishing. <https://nonsequitur.tech/white-papers/tool-orchestration-trust-composition/>

© 2026 Non Sequitur Publishing. All rights reserved. Citation with full attribution is permitted. Reproduction, redistribution, derivative works, and use as input to machine-learning training are **not** permitted without written permission. See <https://nonsequitur.tech/citation-policy/>.
Canonical URL: <https://nonsequitur.tech/white-papers/tool-orchestration-trust-composition/>



ABSTRACT

Each tool invocation in an agentic chain is an *independent trust decision*. Chained tool calls compose as a privilege-aggregation surface where individually-safe capabilities become collectively unsafe. The classical *confused deputy* problem¹ re-emerges in agentic operation at compositional scale: an agent with legitimate access to tools A, B, and C may be induced — through prompt injection, context manipulation, or stale-state substitution — to compose $A \rightarrow B \rightarrow C$ in a sequence that achieves an outcome no individual operator authorized. The composition is the attack.

This paper argues that agentic tool orchestration requires a **compositional threat model** and a corresponding defensive doctrine: **per-call authorization gates** (not session-level trust) and **operator-defined composition policy** that constrains which tool sequences are authorized for which purposes. The thesis extends the classical principle of least authority² with a new principle — *trust composition* — that addresses the structural gap where privilege-aggregation emerges from authorized-individual-actions.

Section 2 develops the parent HGC³AE² framing and surfaces the gap in current authorization frameworks. Section 3 formalizes trust composition as the operational problem: privilege compounding, confused-deputy at compositional scale, and the security composition requirement. Section 4 specifies per-call authorization gates and the composition-policy surface, with explicit reference to the object-capability model³ as a constructive alternative to ACL-based session-level trust. Section 5 places the discipline within MITRE ATT&CK and OWASP LLM Top 10. Section 6 closes with limitations.

The central claim is that **session-level trust is structurally insufficient for agentic tool orchestration**: the threat surface is at the composition layer, not the per-tool layer, and the defense must operate at the composition layer accordingly.

HOW TO CITE

Justin H. Kuiper, CISSP (2026). *Tool Orchestration as a Confused-Deputy and Privilege-Compounding Surface* (v0.1-seed). Non Sequitur Publishing.

© 2026 Non Sequitur Publishing. All rights reserved.

1. INTRODUCTION

1.1 THE TOOL INVOCATION MODEL

Agentic systems operate through tool invocation: the agent reasons against context, selects tools to invoke, executes the tools with parameters derived from the reasoning, and

¹ Norm Hardy, “The Confused Deputy: (or why capabilities might have been invented),” *ACM SIGOPS Operating Systems Review* 22, no. 4 (1988): 36-38, <https://doi.org/10.1145/54289.871709>.

² Jerome H. Saltzer and Michael D. Schroeder, “The Protection of Information in Computer Systems,” *Proceedings of the IEEE* 63, no. 9 (1975): 1278-1308.

³ Mark S. Miller, *Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control* (PhD diss., Johns Hopkins University, 2006).



incorporates tool outputs into subsequent reasoning. A single agent operation may invoke dozens of tools across an operating cycle; chained tool calls are the normal mode, not an exceptional case.

Each tool invocation is, structurally, an *access decision*: the agent decides to call this tool with these parameters at this moment. In current platform designs, the access decision is gated at *session level*: the agent has the tool available throughout the session, with per-call authorization decisions left to the agent's reasoning (i.e., not architecturally enforced).

1.2 THE COMPOSITION PROBLEM

Session-level trust has a structural failure mode: **individually-safe tool calls can compose into collectively-unsafe sequences**. An agent with legitimate access to tools A (read customer email), B (summarize text), and C (post to external channel) has each capability authorized for legitimate purposes. The composition $A \rightarrow B \rightarrow C$ — read customer email, summarize, post externally — is a data-exfiltration capability that no individual tool authorization granted. The composition emerges from the agent's reasoning, not from the operator's authorization.

The classical analog is the *confused deputy* problem:⁴ a service with legitimate access to a resource is induced — typically through misuse of delegation — to access the resource on behalf of an unauthorized requester. Agentic tool orchestration produces confused-deputy at *compositional scale*: not one resource access, but a sequence of accesses whose collective effect is unauthorized.

1.3 CONTRIBUTION

This paper contributes:

Formalizes trust composition as the operational gap: individual authorizations cannot guarantee compositional safety.

Names privilege compounding as the attack pattern: chained calls produce privilege effects no individual call authorized.

Specifies per-call authorization gates as the structural defense, with object-capability semantics as constructive alternative to ACL-based session trust.

Specifies composition policy as the operator-facing surface that bounds which sequences are authorized for which purposes.

2. BACKGROUND

2.1 THE HGC³AE² PARENT FRAMING

The parent HGC³AE² paper specifies governance-first authority as a structural commitment.⁵ The Skipjack Principle 2 (structured task decomposition) requires that agentic

⁴ Norm Hardy, "The Confused Deputy: (or why capabilities might have been invented)," *ACM SIGOPS Operating Systems Review* 22, no. 4 (1988): 36-38, <https://doi.org/10.1145/54289.871709>.

⁵ Justin H. Kuiper, CISSP, *Mitigating Confident Misalignment in Agentic Systems: The HGC³AE² Framework* (v1.0-preprint, 2026), zenodo.org/records/19869285.



execution scope work to the envelope the operator committed; tool invocations are decomposed tasks. The parent framework anticipates per-call discipline but does not develop the compositional threat model this paper supplies.

2.2 THE CONFUSED DEPUTY PROBLEM

The confused deputy was named in 1988⁶ and remains the canonical reference for the access-control failure mode in which a service with legitimate access becomes a vector for unauthorized access. The original example: a compiler with legitimate access to user files and billing system was induced (via filename manipulation) to write user output to the billing file. The compiler did not exceed its authorization; the user did not exceed theirs; the *composition* of the two produced the unauthorized outcome.

Agentic tool orchestration generalizes the pattern: the agent has legitimate access to N tools; the operator did not exceed their authorization; the composition of N tools produces outcomes no party explicitly authorized.

2.3 THE CURRENT AUTHORIZATION GAP

Existing platform designs gate authorization at session level (the agent has tool X available throughout the session) or at per-tool level (the agent can call tool X with these argument types). Neither gates *composition*. Production deployments commonly observe:

Plugin marketplaces offer tools to the agent based on user installation; the user authorizes installation but not per-call composition.

Function-calling APIs validate per-call argument types but do not consider sequence.

Capability scopes in OAuth-like frameworks scope identity-level access but not compositional sequence.

The gap is the composition layer.

3. TRUST COMPOSITION: THE FORMAL PROBLEM

3.1 DEFINING TRUST COMPOSITION FAILURE

A *trust composition failure* occurs when a sequence of authorized tool invocations produces an outcome no operator-pinned policy explicitly authorized. Formally:

Given: operator policy P , tool set $T = \{A, B, C, \dots\}$, authorization function $\text{auth}(P, t, \text{params})$ for tool t with parameters params .

For each individual call: $\text{auth}(P, t_i, \text{params}_i) = \text{true}$ for all i . (Each call is authorized.)

For the composition: $\text{outcome}(t_1, t_2, \dots, t_n)$ may produce an effect E such that $\text{auth}(P, E) = \text{false}$. (The composition's effect is unauthorized.)

The mathematical structure is clear: authorization is per-call; outcomes are compositional; the gap is the operational surface.

⁶ Norm Hardy, "The Confused Deputy: (or why capabilities might have been invented)," *ACM SIGOPS Operating Systems Review* 22, no. 4 (1988): 36-38, <https://doi.org/10.1145/54289.871709>.



3.2 PRIVILEGE COMPOUNDING

Privilege compounding is the attack pattern in which the agent's reasoning composes individual authorized capabilities into a sequence whose effective privilege exceeds the per-tool privilege of any constituent. Example patterns:

Read-summarize-post. Read access to internal data + summarization + write access to external channel = exfiltration capability.

Search-correlate-identify. Per-record-anonymous query + correlation across queries + cross-reference = de-anonymization capability.

Read-modify-write. Read access to record + modification + write to alternative record = data-corruption capability via indirection.

Each pattern is operationally observable; each emerges from authorized-individual-calls; each is unauthorized in compositional effect.

3.3 THE SECURITY COMPOSITION REQUIREMENT

Defensive doctrine requires **security composition**: the conjunction of per-call authorizations must equal authorization of the composition's effect. Where the conjunction is insufficient — the composition produces an effect that no individual authorization addressed — additional governance is required.

The requirement is structurally analogous to *non-interference* in classical security:⁷ the property that low-privilege operations cannot produce high-privilege effects through interaction. Trust composition is the agentic-tool restatement of the requirement.

4. PER-CALL AUTHORIZATION GATES

4.1 THE GATE MODEL

The structural defense is **per-call authorization gates**: every tool invocation passes through a runtime gate that consults operator policy before authorizing. The gate's inputs include the call's tool, parameters, and *the operating context* — specifically, the prior calls in this operating cycle, the composition policy, and the persona authority.

The gate's decision is per-call but operates against compositional policy. The simplest expression: deny calls that would produce a composition the operator did not authorize. More sophisticated implementations evaluate composition cost across the operating cycle and surface composition risk to the operator as advisory.

4.2 COMPOSITION POLICY

Composition policy is the operator-facing surface that bounds which tool sequences are authorized for which purposes. Policy structure (illustrative):

`composition_policies:`

-

`purpose:`

`"customer-support-summarize-only"`

⁷ J. A. Goguen and J. Meseguer, "Security Policies and Security Models," *Proceedings of the 1982 IEEE Symposium on Security and Privacy*, 1982. (Canonical reference for non-interference.)



```

allowed_tools:      [customer_db_read,      summarize]
                    disallowed_compositions:
-      "customer_db_read      →      external_send"
-      "customer_db_read      →      file_write"
rationale: "Read-summarize is authorized; outbound emission is not."
-      purpose:      "incident-response-investigation"
allowed_tools:      [siem_query,      ticket_create,      vendor_api_query]
                    require_human_approval:
-      "any composition involving > 3 distinct tools in single cycle"
rationale: "Wide-tool composition during IR requires human approval per IR policy."

```

The policy artifacts compose into the AZT framework⁸ as policy-as-code; the per-call gate is the AZT enforcement-point pattern adapted for compositional decisions.

4.3 HUMAN GOVERNANCE AT THE PER-CALL GATE

The gate fails-closed: unauthorized compositions are blocked. The operator's response options are:

Authorize the composition. The operator's commit creates a temporary or durable policy update.

Decompose the request. The operator may split the request into multiple operator-authorized sub-requests, each within composition policy.

Refuse. The composition is not in operational scope; the agent declines the request to the user.

The Skipjack Principle 3 (explicit uncertainty signaling)⁹ applies at the gate: composition decisions are surfaced to the operator with the compositional analysis the gate produced.

4.4 THE OBJECT-CAPABILITY MODEL AS CONSTRUCTIVE ALTERNATIVE

The object-capability model¹⁰ offers a constructive alternative to ACL-based session trust. In an object-capability system, capability is not a session-level grant; it is a runtime token whose possession is required for each invocation. The token's scope is per-invocation (or per-sub-operation); composition is governed by token-transfer policy.

Agentic tool orchestration is well-suited to object-capability semantics: tools issue capability tokens for specific operations; the agent's reasoning produces token-transfer-and-invocation chains; the runtime enforces that each invocation has the requisite token. Composition is governed by which tokens an agent may legitimately combine, which becomes the operator's composition policy expressed in capability-transfer rules.

This is not the only valid path; ACL-with-composition-policy is a workable alternative. But object-capability is structurally aligned with the compositional threat model in a way ACL is not, and platforms designing for AZT-aligned compositional security should consider it.

⁸ Justin H. Kuiper, CISSP, *Governance-Gated Execution as an Agentic Zero-Trust Reference Model* (v0.1-seed, 2026), nonsequitur.tech/white-papers/agentic-zero-trust/.

⁹ Justin H. Kuiper, CISSP, *Mitigating Confident Misalignment in Agentic Systems: The HGC³AE² Framework* (v1.0-preprint, 2026), zenodo.org/records/19869285.

¹⁰ Mark S. Miller, *Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control* (PhD diss., Johns Hopkins University, 2006).



5. FRAMEWORK PLACEMENT

5.1 MITRE ATT&CK PLACEMENT

The MITRE ATT&CK framework¹¹ taxonomizes adversarial techniques. Trust composition failures map to several techniques:

TA0005 Defense Evasion — particularly T1078 (Valid Accounts) and T1550 (Use Alternate Authentication Material); compositional misuse of valid credentials.

TA0006 Credential Access — particularly indirect-credential-acquisition patterns.

TA0007 Discovery — privilege compounding for reconnaissance.

TA0009 Collection — privilege compounding for data aggregation.

TA0010 Exfiltration — the read-summarize-post pattern.

Each of the above techniques, when executed via agentic tool composition, presents differently from classical execution: the adversary need not break credentials or escalate privileges; the adversary needs only to induce the agent to compose authorized calls in a sequence whose effect is the unauthorized outcome.

5.2 OWASP LLM TOP 10 ALIGNMENT

OWASP LLM Top 10¹² LLM07 (insecure plugin design) and LLM08 (excessive agency) cover adjacent surfaces. LLM07's "plugin scope" lens overlaps with per-call authorization but does not formalize composition. LLM08's "excessive agency" names the broader risk but does not specify the compositional mechanism. This paper supplies the missing structural specification.

5.3 COMPOSITION WITH FAMILY THESES

Trust composition composes with the other HGC³AE² cyber-pillar theses:

cyb-01 (CMAS)¹³ — confident misalignment can induce trust-composition failures by surfacing tool-call sequences with confidence the operator's trust heuristic accepts.

cyb-06 (AZT)¹⁴ — AZT's tool pillar specifies individual authorization; this paper extends the discipline to compositional authorization.

cyb-08 (SOC reconciliation doctrine)¹⁵ — SOC checkpoints can include composition-policy review for AI-assisted hunt actions.

11 MITRE, *ATT&CK Framework*, <https://attack.mitre.org/>.

12 OWASP, *OWASP Top 10 for Large Language Model Applications* (2024), <https://owasp.org/www-project-top-10-for-large-language-model-applications/>.

13 Justin H. Kuiper, CISSP, *Confident Misalignment as an Adversarial Attack Surface* (v0.1-seed, 2026), nonsequitur.tech/white-papers/confident-misalignment-attack-surface/.

14 Justin H. Kuiper, CISSP, *Governance-Gated Execution as an Agentic Zero-Trust Reference Model* (v0.1-seed, 2026), nonsequitur.tech/white-papers/agentic-zero-trust/.

15 Justin H. Kuiper, CISSP, *Reconciliation Checkpoints as SOC Hunt-Cycle Doctrine* (v0.1-seed, 2026), nonsequitur.tech/white-papers/reconciliation-soc-doctrine/.



cyb-10 (human-authority chain-of-custody)¹⁶ — composition decisions become chain-of-custody entries.

6. LIMITATIONS AND CONCLUSION

6.1 LIMITATIONS

Composition-policy authoring requires operator domain expertise. In high-tool-count deployments, enumerating allowed and disallowed compositions may exceed practical authoring capacity; policy synthesis from operator examples is a research direction not developed here.

The object-capability model has implementation cost. Platforms designed around ACL-style authorization require substantial re-architecture to adopt object-capability semantics natively; hybrid approaches (composition-policy over ACL) are operationally feasible but less structurally clean.

The compositional threat surface evolves with tool ecosystem. New tool classes (e.g., autonomous-code-execution, payment-tools) introduce composition patterns not anticipated at policy authoring; ongoing review is required.

6.2 CONCLUSION

Tool orchestration is the compositional surface of agentic operation. Per-call authorization gates and operator-defined composition policy convert the surface from an implicit-trust failure mode into a governance-controlled enforcement boundary. The structural commitment: **session-level trust is insufficient; per-call composition-aware authorization is required.**

This is Thesis Nine (cyb-09) of the HGC³AE² Cyber Pillar derivative family. Composes with cyb-06 (AZT) and cyb-10 (chain-of-custody) into the per-action governance architecture for agentic systems.

REFERENCES

— end v0.1-seed draft —

Drafting state: v0.1 CYB-09 (chain v0.1 step 6). 6-section canon shape. PR count: 12 — parent + Hardy confused-deputy + Saltzer/Schroeder + Miller obj-cap + Goguen non-interference + ATT&CK + OWASP-LLM + OPA + Cedar + 4 cross-thesis refs (cyb-01, cyb-06, cyb-08, cyb-10). Meets ≥12 floor.

¹⁶ Forthcoming CYB-10 *Human Authority Boundary as Chain-of-Custody for Agentic Outputs* (in concurrent drafting; this dispatch).